

Տերմինների և գործիքների ուղեցույց

Այս ուղեցույցը բացատրում է դասընթացում հանդիպող հիմնական հասկացություններն ու գործիքները: Այն կօգնի հասկանալ՝ ինչ ենք պատրաստում, ինչի համար է յուրաքանչյուր գործիքը, և ինչպես են դրանք աշխատում միասին:

Մեր ընդհանուր նպատակը

Ստեղծում ենք playbook-ներ՝ կազմակերպության SOAR հարթակում օգտագործելու համար: Դրանք կօգնեն անվտանգության թիմին ուսումնասիրել ահազանգերը, հավաքել տեղեկությունները և կազմակերպել անհրաժեշտ գործողությունները: Հարթակը պայմանականորեն անվանում ենք X SOAR:

Անվտանգության թիմը և համակարգերը

SOC

SOC նշանակում է Security Operations Center: Սա անվտանգության աշխատանքը կազմակերպող թիմն է կամ կենտրոնը: Այն հետևում է ահազանգերին, ուսումնասիրում կասկածելի դեպքերը և կազմակերպում արձագանքը:

Մեր նախագծում. playbook-ների արդյունքներից օգտվելու են անվտանգության վերլուծաբանները և դեպքի պատասխանատուները:

SIEM

SIEM նշանակում է Security Information and Event Management: Այն տարբեր համակարգերից հավաքում է գրանցումներ և օգնում գտնել կասկածելի իրադարձություններ: Օրինակ՝ մի քանի անհաջող մուտքից հետո ստեղծում է ահազանգ:

Մեր նախագծում. SIEM Control playbook-ը ստանալու է դեպքի հետ կապված գրանցումները: SIEM-ից պահանջվելու է տեղեկություն կարդալու հաստատված կապ:

SOAR

SOAR նշանակում է Security Orchestration, Automation and Response: Այն օգնում է տարբեր գործիքների և մարդկանց աշխատանքը միավորել մեկ գործընթացի մեջ: Կարող է տեղեկություն ստանալ, գործարկել ստուգում և սպասել մարդու հաստատմանը:

Մեր նախագծում. մեր պատրաստած playbook-ները կկազմակերպեն այդ քայլերը նպատակային հարթակում: Հարթակի ներքին կառուցվածքը չենք նախագծում:

SIEM-ը տրամադրում է գրանցումներ և ահազանգեր: SOAR-ը կազմակերպում է դրանց հետագա մշակումը: SOC-ի աշխատակիցները գնահատում են արդյունքները և որոշումներ ընդունում:

Դեպքը և դրա մշակման քայլերը

Event և Alert

Event-ը գրանցված իրադարձությունն է, օրինակ՝ օգտվողի մուտք կամ կարգավորման փոփոխություն: Alert-ը ահազանգ է, որ այդ իրադարձությունը կամ դրանց խումբը ստուգելու կարիք ունի: Ամեն ահազանգ հաստատված խնդիր չէ:

Մեր նախագծում. գործընթացը սկսում ենք կասկածելի փոփոխության մասին ահազանգից:

Incident և Case

Incident-ը անվտանգության դեպք է, որը պահանջում է արձագանք: Case-ը դրա ուսումնասիրման աշխատանքային գրառումն է՝ տեղեկություններով, առաջադրանքներով և որոշումներով: Case կարող ենք բացել նաև մինչև խնդրի հաստատվելը:

Մեր նախագծում. playbook-ների պատասխանները պահում ենք նույն գրառման մեջ, որպեսզի ամբողջ ընթացքը տեսանելի լինի:

Playbook և Workflow

Playbook-ը նկարագրում է՝ ինչ քայլերով մշակել որոշակի դեպք: Workflow-ը այդ քայլերի կազմակերպված ընթացքն է՝ ինչից հետո ինչ է կատարվում և ինչ պատասխանների ենք սպասում:

Մեր նախագծում. գլխավոր playbook-ը միացնում է մնացած օժանդակ playbook-ների աշխատանքը:

Automation և Orchestration

Automation-ը մեկ քայլի ավտոմատ կատարումն է: Orchestration-ը մի քանի քայլերի և գործիքների աշխատանքի կազմակերպումն է:

Մեր նախագծում. SIEM-ում որոնումը կարող է լինել ավտոմատ քայլ: Որոնումը, AI ամփոփումը և մարդու հաստատումը մեկ ընթացքի մեջ միացնելը՝ աշխատանքի կազմակերպում:

Approval և Business Impact

Approval-ը լիազորված անձի հաստատումն է կոնկրետ գործողության համար: Business Impact-ը ցույց է տալիս՝ դեպքն ինչպես է ազդում կազմակերպության աշխատանքի վրա:

Մեր նախագծում. նախ պարզում ենք ազդեցությունը, հետո անհրաժեշտ գործողությունն ուղարկում հաստատման: Նախկին փոփոխության թույլտվությունը նոր գործողության հաստատում չէ:

Ինչպես է կազմակերպվում մշակումը

DevOps

DevOps-ը ծրագրի մշակման և շահագործման թիմերի համատեղ աշխատանքի մոտեցում է: Նպատակն է փոփոխություններն ավելի հեշտ պատրաստել, ստուգել և հասցնել օգտագործողներին: Մեր նախագծում. playbook-ը մշակում ենք այնպես, որ մյուս թիմը կարողանա այն գործարկել և սպասարկել:

DevSecOps

DevSecOps-ը նույն աշխատանքի մեջ ներառում է անվտանգությունը՝ սկզբից մինչև օգտագործում: Օրինակ՝ նախապես ստուգում ենք իրավունքները, գաղտնի տվյալները և ծրագրի հայտնի խնդիրները:

Platform Engineering

Սա թիմերի համար ընդհանուր գործիքներ և օգտագործման պարզ ուղիներ ստեղծելու աշխատանքն է: Օրինակ՝ պատրաստի փորձարկման միջավայր կամ ստանդարտ եղանակ՝ ծրագիրը թողարկելու համար:

Մեր նախագծում. կօգտվենք հարթակի թիմի տրամադրած հնարավորություններից և կհանձնենք վերօգտագործվող playbook-ներ: Սա չի նշանակում, որ կառուցում ենք ամբողջ SOAR հարթակը:

Development Test & Production

Development-ը մշակման միջավայրն է: Test կամ sandbox միջավայրում փորձարկում ենք աշխատանքը՝ առանց իրական ծառայություններին վնասելու: Production-ը իրական օգտագործման միջավայրն է:

Մեր նախագծում. սկզբում օգտագործում ենք փորձնական տվյալներ, ապա հարթակի թիմի հետ ստուգում կապերը: Իրական գործածությունը պահանջում է հաստատված թողարկում:

Git և համատեղ աշխատանք

Version Control և Git

Version Control-ը ֆայլերի փոփոխությունների պատմությունը պահելու եղանակ է: Git-ը դրա համար օգտագործվող գործիք է: Այն ցույց է տալիս՝ ինչ է փոխվել և թույլ է տալիս համեմատել կամ վերականգնել տարբերակները:

Մեր նախագծում. Git-ում պահում ենք playbook-ների նկարագրությունները, կոդը, կարգավորումները և թեստերը:

Repository Commit և Branch

Repository-ն նախագծի ֆայլերն ու դրանց պատմությունը պահող տարածքն է: Commit-ը պահպանված փոփոխությունների խումբ է: Branch-ը առանձին աշխատանքային ուղղություն է, որտեղ փոփոխություն ենք պատրաստում:

Մեր նախագծում. նոր playbook-ի համար բացում ենք branch, կատարում փոփոխությունները և պահում դրանք հասկանալի commit նկարագրությամբ:

GitHub և Pull Request

GitHub-ը Git նախագծերը առցանց պահելու և միասին աշխատելու ծառայություն է: Pull Request-ը առաջարկ է՝ մեր փոփոխությունը թիմի հիմնական տարբերակին միացնելու համար: Reviewer-ը կարդում և ստուգում է այն:

Մեր նախագծում. թիմակիցը ստուգում է փոփոխությունը մինչև այն ընդունելը: GitLab-ը կարող է ծառայել որպես այլընտրանք: Երկուսն էլ միաժամանակ պարտադիր չեն:

Օգտակար փոքր օրինակ

```
git status  
git diff
```

Առաջին հրամանը ցույց է տալիս փոփոխված \$այլերը, երկրորդը՝ դրանց տարբերությունները: Git-ը փոփոխությունների պատմությունն է կառավարում:

CI CD և ավտոմատ ստուգումներ

CI

CI նշանակում է Continuous Integration: Թիմի փոփոխությունները պարբերաբար միացվում են, իսկ ավտոմատ ստուգումները օգնում են արագ նկատել սխալները:

CD

CD-ն նշանակում է Continuous Deployment: Հաջող ստուգումներից հետո կոդի տեղադրումը իրականացվում է ավտոմատ:

GitHub Actions

Սա GitHub-ի ավտոմատացման գործիքն է: Այն կարող է փոփոխության պահին գործարկել թեստեր, ստուգել \$այլերը և պատրաստել թողարկման փաթեթը:

Docker և Kubernetes

Container և Image

Container-ը ծրագիրը մեկուսացված միջավայրում գործարկելու ձև է: Image-ը դրա պատրաստի փաթեթն է՝ ծրագրով և անհրաժեշտ \$այլերով: Image-ից ստեղծվում է աշխատող container:

Docker և Docker Compose

Docker-ը container-ներ պատրաստելու և գործարկելու գործիքների հավաքածու է: Dockerfile-ը նկարագրում է image-ի պատրաստումը: Docker Compose-ը մեկ \$այլով նկարագրում է մի քանի ծառայությունների համատեղ գործարկումը:

Kubernetes

Kubernetes-ը կառավարում է container-ներով ծրագրերի գործարկումը: Օգնում է պահել անհրաժեշտ քանակի աշխատող օրինակներ և փոխարինել խափանվածները: Cluster-ը միասին աշխատող մեքենաների խումբն է, իսկ Pod-ը գործարկման փոքր միավորը:

Մեր նախագծում, փոքր գործնական վարժությամբ կտեսնենք վերագործարկումն ու հասանելիության ստուգումը: Այն անհրաժեշտ չէ յուրաքանչյուր playbook գրելու համար:

kind և kubectl

kind-ը տեղային Kubernetes cluster ստեղծելու գործիք է: kubectl-ը Kubernetes-ին հրամաններ ուղարկելու գործիք է: Մեր նախագծում, կօգտագործենք միայն Kubernetes-ի առանձին փորձի դեպքում:

Ենթակառուցվածք Cloud և Linux

Infrastructure as Code կամ IaC

IaC-ը ենթակառուցվածքը \$այլերով նկարագրելու մոտեցում է: Օրինակ՝ գրում ենք, թե ինչ փորձնական մեքենա և ցանց է պետք, որպեսզի նույն միջավայրը հնարավոր լինի

կրկին ստեղծել: Մեր նախագծում. կնկարագրենք միայն դասընթացի համար առանձնացված փորձնական ռեսուրսները:

Terraform

Terraform-ը IaC գործիք է: Այն համեմատում է նկարագրած և առկա վիճակը ու ցույց տալիս նախատեսվող փոփոխությունները: State-ը պահում է կառավարվող ռեսուրսների մասին տեղեկությունը:

Cloud և Virtual Machine

Cloud-ը հաշվարկային ռեսուրսներ ստանալու ծառայություն է, օրինակ՝ AWS, Azure կամ Google Cloud: Virtual Machine-ը վիրտուալ համակարգիչ է՝ իր օպերացիոն համակարգով:

API և տվյալների փոխանակում

API Endpoint և Connector

API-ն ծրագրերի միջև տեղեկություն կամ հրահանգ փոխանցելու պայմանավորված եղանակ է: Endpoint-ը կոնկրետ հարցման հասցեն է: Connector-ը հարթակը տվյալ ծառայությանը կապող բաղադրիչն է: Մեր նախագծում. SOAR-ից կապ կհաստատենք SIEM-ի, փոփոխությունների գրանցման և AI գործիքի հետ՝ օգտագործելով տրամադրված API-ները:

HTTP և Webhook

HTTP-ն ծառայությունների հետ հարցում ու պատասխան փոխանակելու տարածված եղանակ է: GET հարցումը սովորաբար կարդում է տեղեկություն, POST-ը՝ ուղարկում այն: Webhook-ը թույլ է տալիս ծառայությանը իրադարձության պահին ինքնուրույն ծանուցել մեկ այլ ծառայության:

Մեր նախագծում. ահազանգը կարող է հասնել հարթակ webhook-ով, իսկ լրացուցիչ տվյալները՝ API հարցմամբ:

API ստուգելու գործիքներ

Postman-ը հարցումներ պատրաստելու տեսողական գործիք է: curl-ը նույն նպատակով օգտագործվող հրամանային գործիք է: Սկզբում դրանցից մեկով ստուգում ենք կապը, հետո այն ներառում playbook-ում:

AI և դրա օգտագործումը

AI և LLM

AI-ն արհեստական բանականության ընդհանուր անվանումն է: LLM-ը լեզվային մեծ մոդել է, որը կարող է մշակել և ստեղծել տեքստ: Այն կարող է օգտակար ամփոփում տալ, բայց նաև սխալվել:

Մեր նախագծում. AI Alert Validation-ում այն կօգնի ամփոփել ահազանգն ու նշել բաց հարցերը: Վերջնական որոշումը չենք ընդունում միայն AI-ի պատասխանի հիման վրա:

AI API և Model

AI API-ն մոդելին ծրագրից հարցում ուղարկելու եղանակն է: Model-ը այդ հարցումը մշակող մոդելն է: API-ն կապն է, model-ը՝ տեքստը մշակող մասը:

Մեր նախագծում. օգտագործելու ենք հարթակի թիմի հաստատած AI ծառայությունն ու մոդելը: Նախ ստուգելու ենք՝ ինչ տվյալներ է թույլատրվում ուղարկել:

Prompt & Structured Output

Prompt-ը մոդելին տրվող առաջադրանքն ու տեղեկությունն է: Structured output-ը նախապես որոշված կառուցվածքով պատասխան է, օրինակ՝ JSON դաշտերով: Կառուցվածքի ճիշտ լինելը դեռ չի նշանակում, որ փաստերը ճիշտ են:

Մեր նախագծում. կխնդրենք ամփոփում, տեղեկության աղբյուրներ և բաց հարցեր: Չետո կստուգենք նաև պատասխանի փաստերը:

Փորձարկում և անվտանգություն

Test pytest & Mock

Test-ը ստուգում է՝ ծրագիրը տալիս է սպասվող արդյունքը: pytest-ը Python թեստերը գործարկող գործիք է: Mock-ը իրական ծառայությանը փոխարինող փորձնական պատասխան կամ ծրագիր է:

Մեր նախագծում. pytest-ով կստուգենք playbook-ի որոշումները: WireMock-ով կամ պարզ Python ծրագրով կարող ենք նմանակել SIEM-ի պատասխանն ու կապի խափանումը:

Secret & Audit Trail

Secret-ը գաղտնի տվյալ է, օրինակ՝ գաղտնաբառ կամ API key: Audit trail-ը ցույց է տալիս՝ ով, երբ և ինչ գործողություն է կատարել:

Gitleaks & Trivy

Gitleaks-ը ֆայլերում և Git պատմության մեջ փնտրում է հնարավոր գաղտնիքներ: Trivy-ն կարող է փնտրել հայտնի խոցելիություններ և կարգավորման խնդիրներ ծրագրի կամ container image-ի մեջ:

Աշխատանքի վերահսկում և վերականգնում

Monitoring & Observability

Monitoring-ը հետևում է հայտնի ցուցանիշներին և զգուշացնում խնդրի մասին: Observability-ն օգնում է ստացված տվյալներով հասկանալ՝ ինչու է համակարգն այդպես աշխատում:

Logs Metrics & Traces

Log-ը առանձին իրադարձության գրառում է: Metric-ը չափելի թիվ է, օրինակ՝ սխալների քանակը: Trace-ը ցույց է տալիս մեկ հարցման ճանապարհը մի քանի քայլերի միջով:

Prometheus & Grafana

Prometheus-ը հավաքում ու մշակում է ցուցանիշներ: Grafana-ն տարբեր աղբյուրների տվյալները ցույց է տալիս վահանակներով:

Release Rollback & Process Revert

Release-ը օգտագործման համար պատրաստված տարբերակն է: Rollback-ը կարող է վերադարձնել նախորդ տարբերակը: Process Revert-ը արդեն կատարված գործողության հետևանքը վերականգնելու առանձին գործընթաց է:

Ինչ գործիքներ ենք օգտագործելու

Նախագծի հիմնական հավաքածու

- X SOAR. playbook-ների պատրաստում, միացում և փորձարկում՝ հարթակի տրամադրած միջոցներով:
- Git և GitHub. աշխատանքի պահպանում և թիմային ստուգում: GitHub Actions. ավտոմատ թեստեր:
- Python և pytest. օժանդակ կոդ ու թեստեր: JSON և YAML. տվյալներ ու կարգավորումներ:
- Docker և Docker Compose. կրկնվող փորձարկման միջավայր:
- Postman կամ curl. կապերի ստուգում: Հաստատված AI API. ահազանգի ամփոփում:
- Gitleaks. կիրառելի անվտանգության ստուգումներ:

Առանձին վարժությունների գործիքներ

Terraform՝ փորձնական ռեսուրսները նկարագրելու համար: Kubernetes, kind և kubectl՝ container-ների կառավարման փոքր փորձի համար: Linux և տրամադրված տեղային կամ cloud մեքենա՝ ծրագրերը գործարկելու համար: